



MODULE 07

Network Segmentation using Zones and Conduits

Course: Cybersecurity for Embedded & OT Systems

Focus: Limiting impact, protecting safety-critical systems through strategic network design

MODULE 06 RECAP

Recap — Module 06: Network Monitoring for OT Systems



Network monitoring in OT is a defensive, safety-first activity.



Primary goal is visibility, not control or exploitation.



Passive monitoring is preferred to avoid disrupting real-time operations.



Legal and ethical boundaries must always be respected.



Packet capture records traffic; offline analysis examines it safely.



OT traffic is typically stable, repetitive, and predictable.



Abnormal behavior includes new devices, timing changes, and traffic spikes.



Wireshark supports visibility when used in read-only mode.



CSV exports and visualization help identify trends safely.



Observations must be contextualized, verified, and documented.



Understanding normal and abnormal network behavior enables safer detection, analysis, and response in OT environments.

Why Segmentation Matters in OT



Operational Technology systems directly control real physical processes—pumps, valves, conveyor belts, and robotic arms. Unlike traditional IT networks where a slowdown might frustrate users, failures or misconfigurations in OT environments can spread rapidly across interconnected systems, leading to serious consequences.

Flat networks significantly increase:

- **Safety risk** — Faults propagate to critical equipment
- **Downtime impact** — One issue affects multiple production lines
- **Troubleshooting difficulty** — Unclear boundaries complicate diagnosis



Segmentation is about **control and containment**, not complete isolation. Smart boundaries enable both security and operational efficiency.

The Problem with Flat OT Networks

Unrestricted Communication

All devices can talk to each other without restrictions, creating countless potential attack paths and fault propagation routes.

Cascading Failures

A single mistake or misconfiguration can rapidly affect multiple systems across the network, magnifying the impact exponentially.

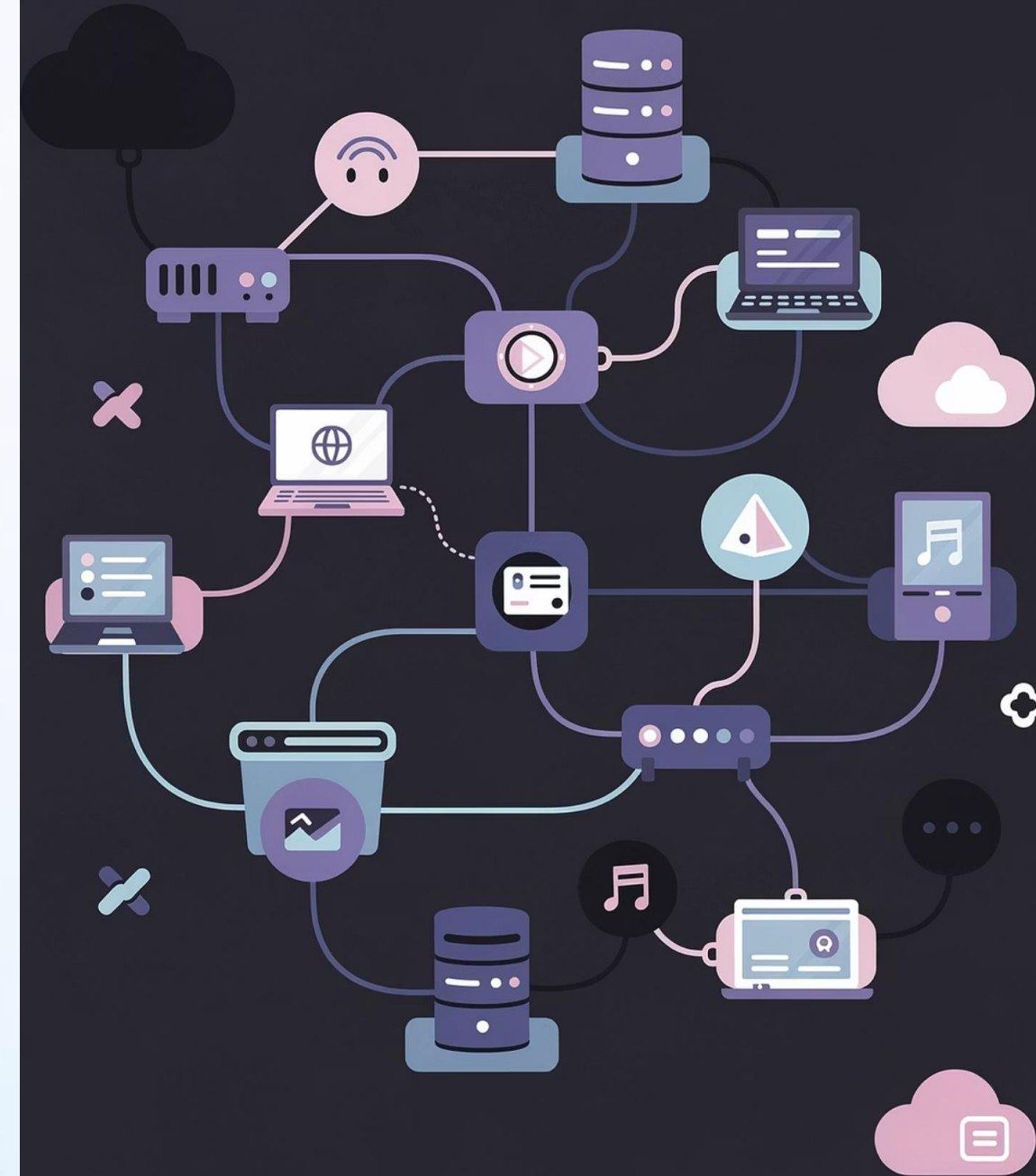
Rapid Spread

Malware or operational faults spread easily through unrestricted pathways, jumping from one system to another without barriers.

Monitoring Chaos

With no clear boundaries, security monitoring becomes unclear and ineffective—making it difficult to identify the source and scope of incidents.

What works for convenience in initial deployment often fails catastrophically when safety and security are tested.



Benefits of Segmented OT Networks

Strategic network segmentation transforms OT security from reactive to proactive, creating defensive layers that protect critical operations.



Contain Faults & Incidents

Problems stay within defined boundaries instead of spreading across the entire network



Protect Safety-Critical Controllers

Critical PLCs and control systems remain isolated from less secure zones



Reduce Unintended Interactions

Eliminate unnecessary communication paths that create risk without operational value



Improve Visibility & Monitoring

Clear boundaries enable precise monitoring and faster incident detection

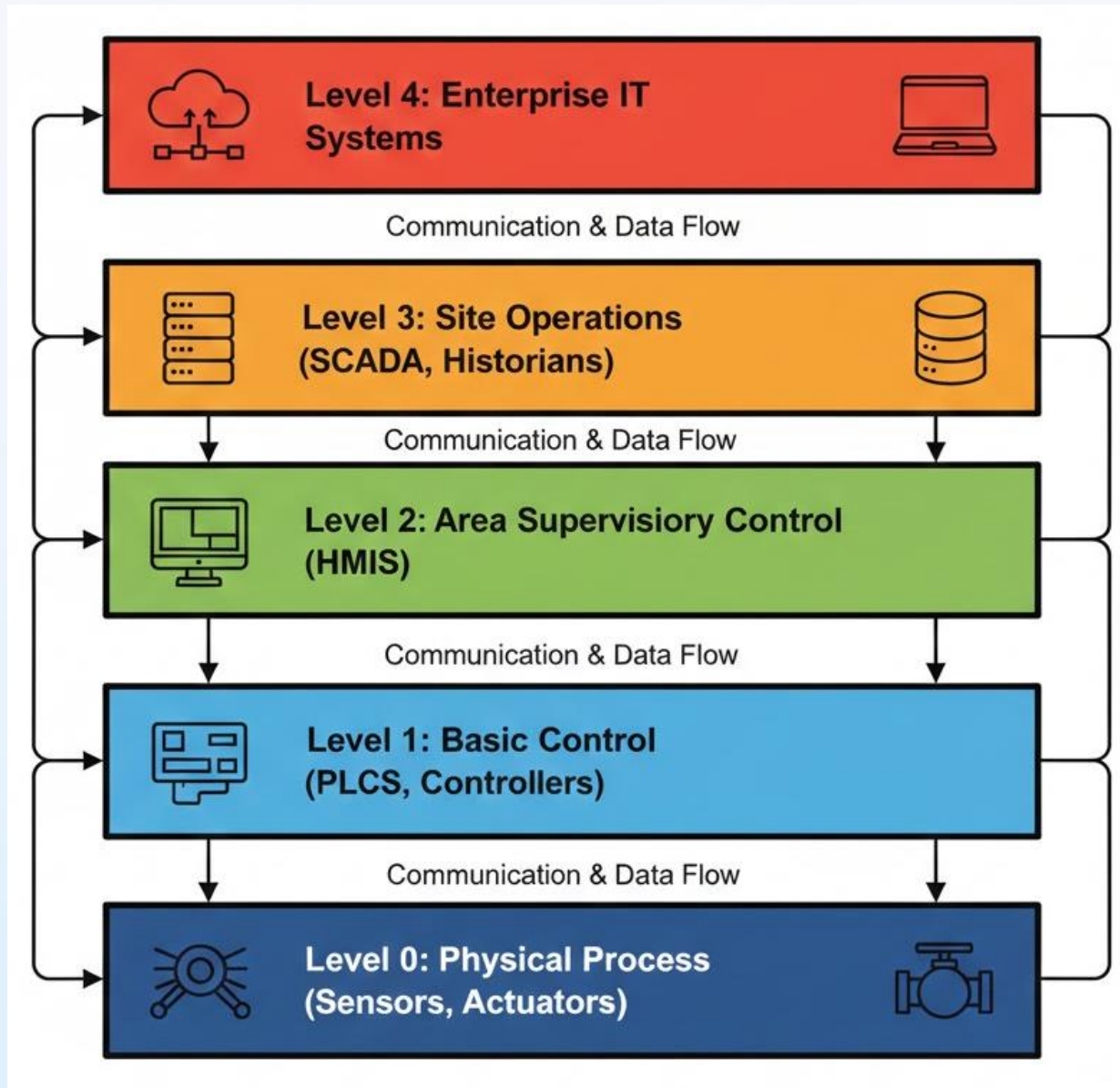


Support Compliance & Audits

Documented segmentation demonstrates security controls to regulators and auditors

Primary Goal: Keep problems local and contained, preventing system-wide cascading failures that threaten safety and production.

Introducing the Purdue Model



The Purdue Model for Industrial Control Systems provides a foundational framework for understanding where different systems belong within an OT environment. Developed in the 1990s at Purdue University, it has become the industry standard for OT network architecture.

The model helps teams:

- Organize systems by their operational function
- Design appropriate communication boundaries
- Make informed decisions about data flow
- Understand risk levels at each tier

❏ The Purdue Model is a **reference framework** for logical organization, not a literal firewall architecture. It guides thinking, not implementation details.

Purdue Model Levels (Simplified)



Level 0: Physical Process

The physical world—sensors measuring temperature and pressure, actuators controlling valves and motors, instruments monitoring conditions



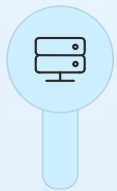
Level 1: Control

PLCs, RTUs, and variable frequency drives that execute real-time control logic and directly manage the physical process



Level 2: Supervisory

Human-machine interfaces (HMIs) and operator workstations that provide process visualization and manual control capabilities



Level 3: Operations

SCADA systems, historians, and manufacturing execution systems that manage site-wide operations and store time-series data



Level 4: Enterprise IT

Business systems including ERP, email, and corporate databases that support organizational operations

Understanding these levels is essential for placing security boundaries correctly and ensuring proper data flow between operational tiers.

Why Levels Need Boundaries

IT Issues Reach Control Systems

Without boundaries, enterprise malware, patch conflicts, or network changes can directly impact safety-critical controllers running continuous processes.

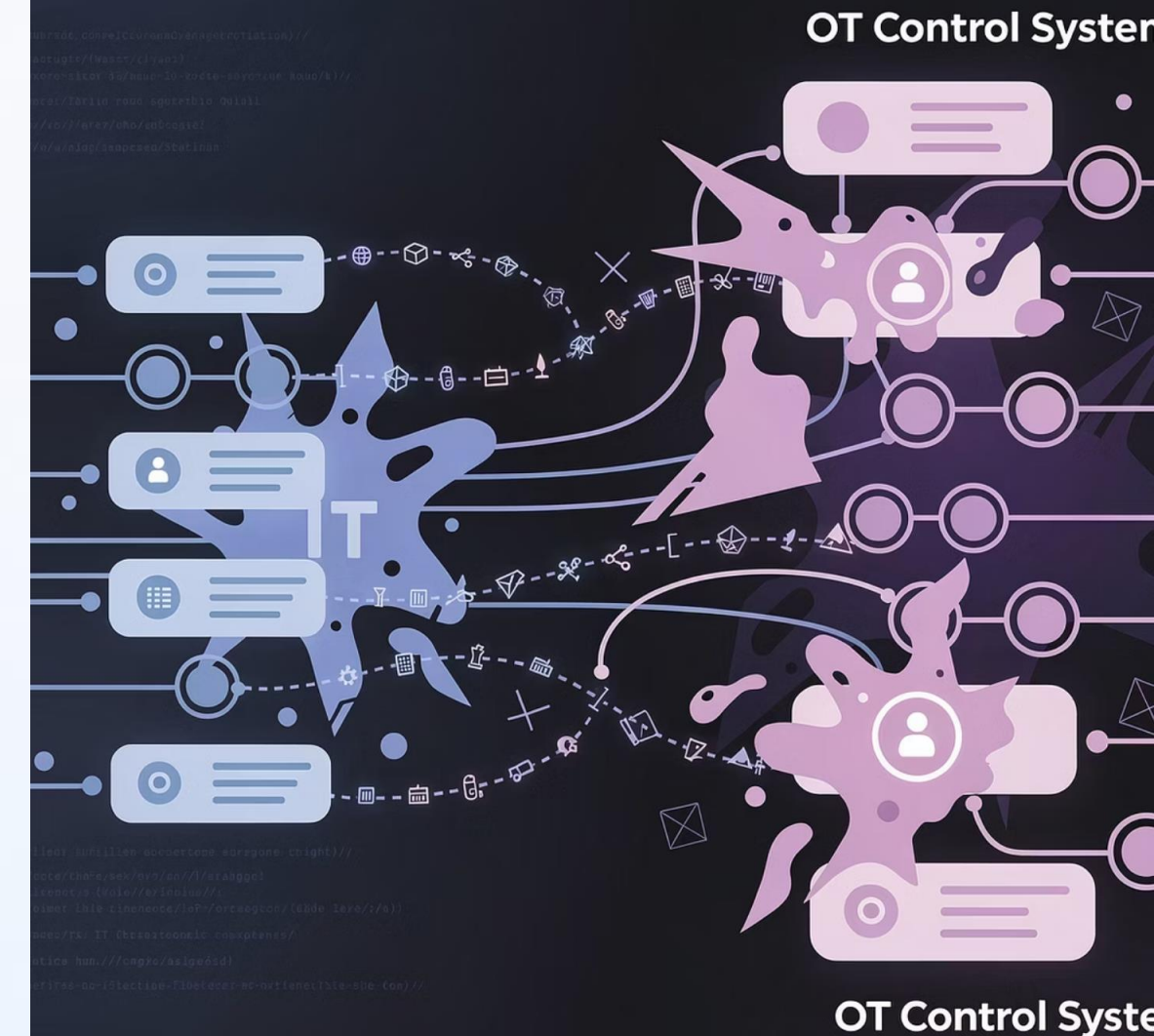
Maintenance Mistakes Spread Widely

A misconfigured device or accidental broadcast storm in one area can cascade across multiple operational zones, affecting unrelated systems.

Security Monitoring Becomes Unclear

Without defined boundaries, distinguishing normal operations from anomalous behavior becomes nearly impossible, degrading detection capabilities.

Core Principle: Boundaries protect lower levels (closer to the physical process) from the higher-risk zones above them. Level 0 and 1 should have the strongest protections, as they directly control physical safety.

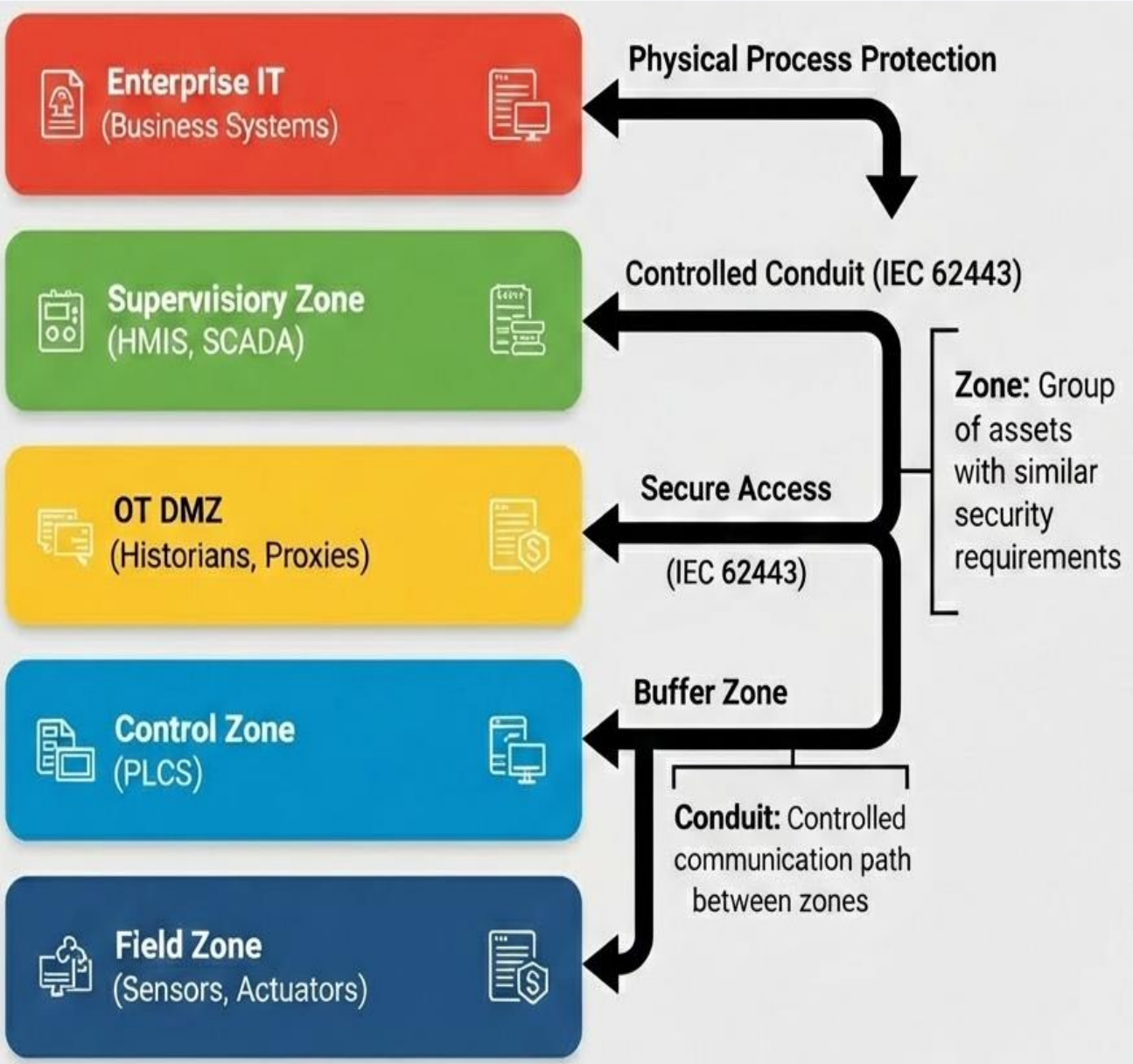


Zones and Conduits (IEC 62443)

The IEC 62443 series of standards introduces a more flexible and risk-based approach to OT network architecture through two fundamental concepts:

**Zones**
Logical or physical groupings of assets that share similar security requirements, risk profiles, and operational characteristics

**Conduits**
Controlled communication pathways between zones that define exactly what traffic is permitted, monitored, and logged



This model designs security architecture around **risk profiles and functional requirements** rather than rigid hierarchical levels. It allows for more granular control and better alignment with actual operational needs.

Example Zones in OT

While every facility is unique, common zone architectures follow similar patterns based on functional requirements and risk profiles.

01	02	03
Field Zone	Control Zone	Supervisory Zone
Sensors, actuators, instruments—direct interface with physical processes, highest safety criticality, lowest connectivity needs	PLCs, RTUs, safety systems—real-time control logic execution, millisecond-level timing requirements, isolated from disruptions	HMIs, operator workstations, engineering stations—human interaction point, process visualization, manual control capabilities
04	05	
OT DMZ	Enterprise IT	
Historians, data aggregators, proxy servers—buffer zone between OT and IT, enables data sharing without direct connections	Business systems, email, corporate databases—higher connectivity, regular patching, different risk profile from OT	

❑ Not all zones require equal exposure or connectivity. Zones closer to physical processes should have the most restrictive access policies.

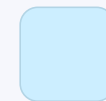
What Conduits Control

Conduits are the enforcement points of your segmentation strategy. They transform architectural designs into operational reality by controlling every aspect of inter-zone communication.



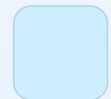
Who can talk to whom

Define specific source and destination addresses—never allow blanket "any to any" rules in OT environments



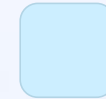
Which protocols are allowed

Permit only necessary industrial protocols (Modbus, OPC, EtherNet/IP) and block everything else at the network layer



When communication is permitted

Implement time-based rules for maintenance windows, vendor access periods, or scheduled data transfers



How access is monitored

Log all connection attempts, alert on policy violations, and maintain audit trails for compliance and forensics

Key Principle: Conduits prevent unnecessary communication paths. If two zones don't need to talk for operational reasons, they shouldn't be able to—regardless of convenience.

Firewalls & Data Diodes (Conceptual)

Segmentation strategies are enforced through purpose-built network security devices. Each technology serves different use cases based on risk tolerance and operational requirements.



Firewalls

Bidirectional devices that allow or block defined traffic patterns based on rules—the most common enforcement mechanism for conduits



Data Diodes

Hardware-enforced one-way data flow devices—physically impossible for data to flow backward, used for highest security zones

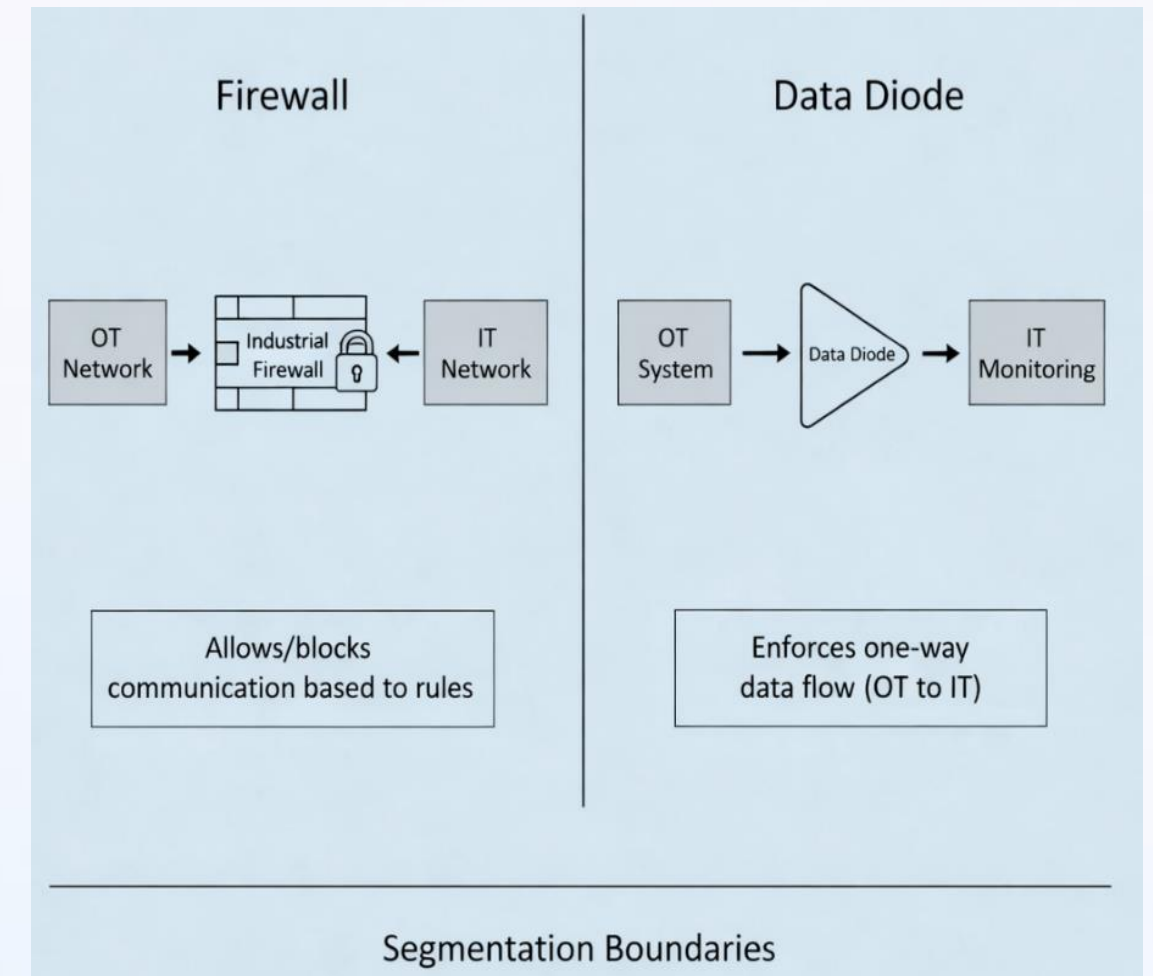


Switches & Routers

Provide logical separation through VLANs and routing policies—lower cost but require careful configuration management



Technology controls **enforce architectural decisions**—they don't replace the need for thoughtful design. Bad architecture with expensive firewalls still creates risk.



Why Data Diodes Are Used

1

Allow Data Out of OT

Process data, logs, and metrics can flow outward to historians and business systems for analysis and reporting

2

Prevent Data Flowing Back In

Physical hardware design makes it impossible for commands, malware, or unauthorized traffic to enter the OT zone

3

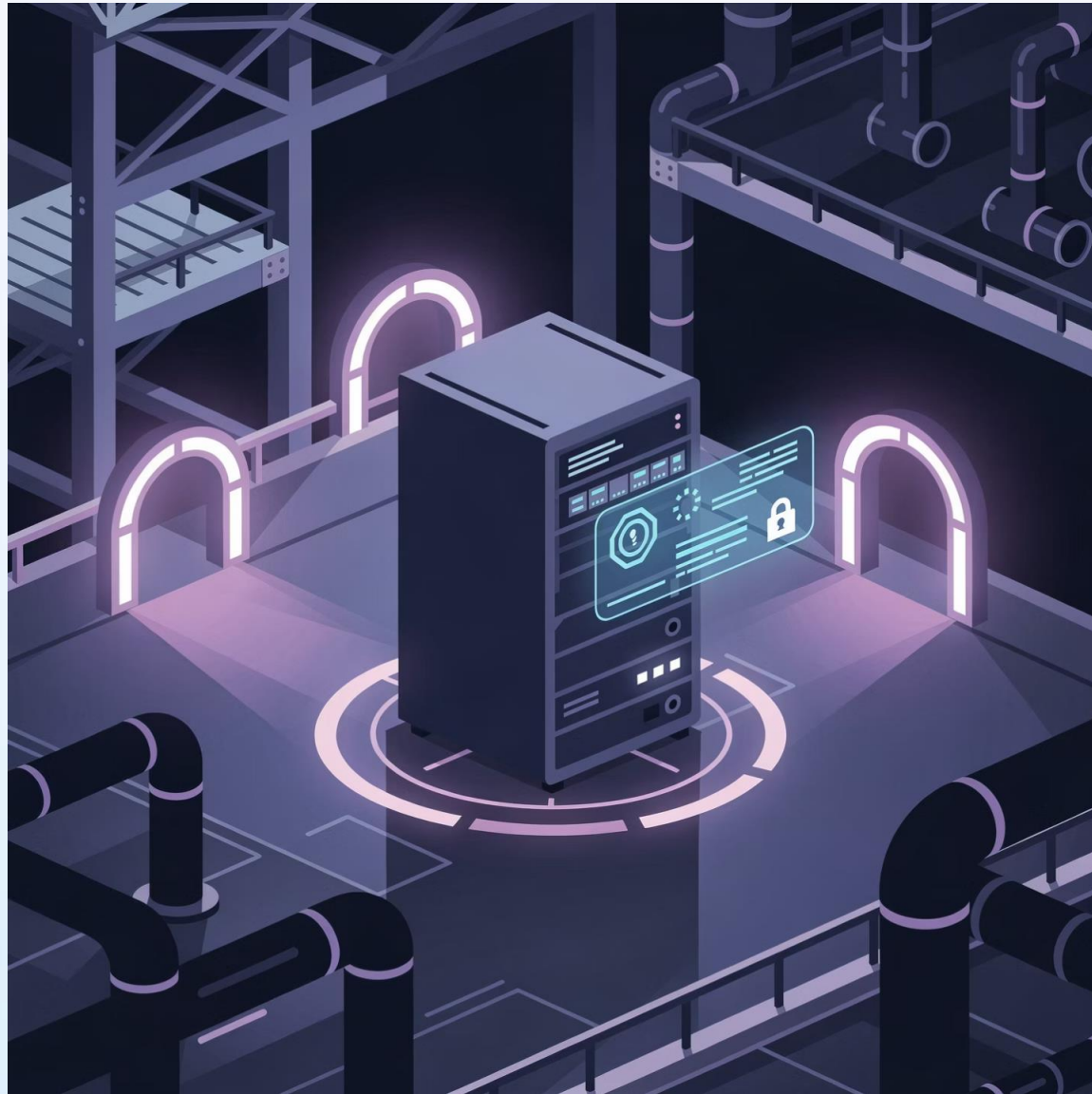
Reduce Malware Spillover Risk

Even if enterprise IT networks are compromised, the data diode provides absolute protection against reverse infection

Data diodes are deployed where **safety and integrity are absolutely critical**—nuclear facilities, utilities, chemical plants, and other high-consequence environments. The unidirectional nature eliminates entire classes of cyber attacks while still enabling essential data sharing for business operations.

Trade-off: Configuration changes or updates to OT systems protected by data diodes require physical access or out-of-band management networks, increasing operational complexity.

Jump Hosts for Remote Access



Remote access to OT environments is sometimes operationally necessary—for vendor support, remote troubleshooting, or distributed operations teams. Jump hosts provide a secure architecture for these requirements.

A properly configured jump host provides:

- **Single controlled entry point** — All remote access funnels through one hardened system
- **Strong authentication** — Multi-factor authentication before any OT access is granted
- **Session logging** — Complete recording of all actions for audit and forensic purposes
- **Time-limited access** — Automatic credential expiration after defined maintenance windows
- **Role-based restrictions** — Users see only systems relevant to their job function

❑ **Critical Rule:** No direct vendor access to controllers. All connections must transit through the monitored jump host, creating visibility and accountability.

Vendor Access Best Practices

Third-party vendor access represents one of the highest-risk scenarios in OT security. Vendors need connectivity to support their equipment, but unrestricted access creates unacceptable risk.

Dedicated Jump Host

Vendors connect only to isolated jump hosts—never directly to the production OT network or control systems

Role-Based Permissions

Grant access only to specific devices the vendor is responsible for—no network-wide visibility or lateral movement

Approval Workflows

Require formal approval from operations before activating any vendor access—no standing credentials or always-on VPNs

Session Recording

Log every keystroke and command for compliance, troubleshooting, and forensic analysis if incidents occur

Automatic Access Expiry

Credentials automatically disable after scheduled maintenance windows—force renewal for each access request

Convenience should never bypass segmentation. A five-minute shortcut can create years of vulnerability.

Least Privilege Communication

The principle of least privilege applies not just to user access, but to network communication itself. Every connection between zones should be intentionally designed and continuously justified.

Allow Only Required Protocols

If only Modbus TCP is operationally necessary, block HTTP, SMB, and all other protocols at the firewall—even if devices technically support them

Restrict Source and Destination

Define specific IP addresses for both ends of communication—avoid subnet-wide rules or "any" statements that create unnecessary exposure

Limit Communication Frequency

For periodic data transfers, implement time-based rules that allow connections only during scheduled windows, blocking them otherwise

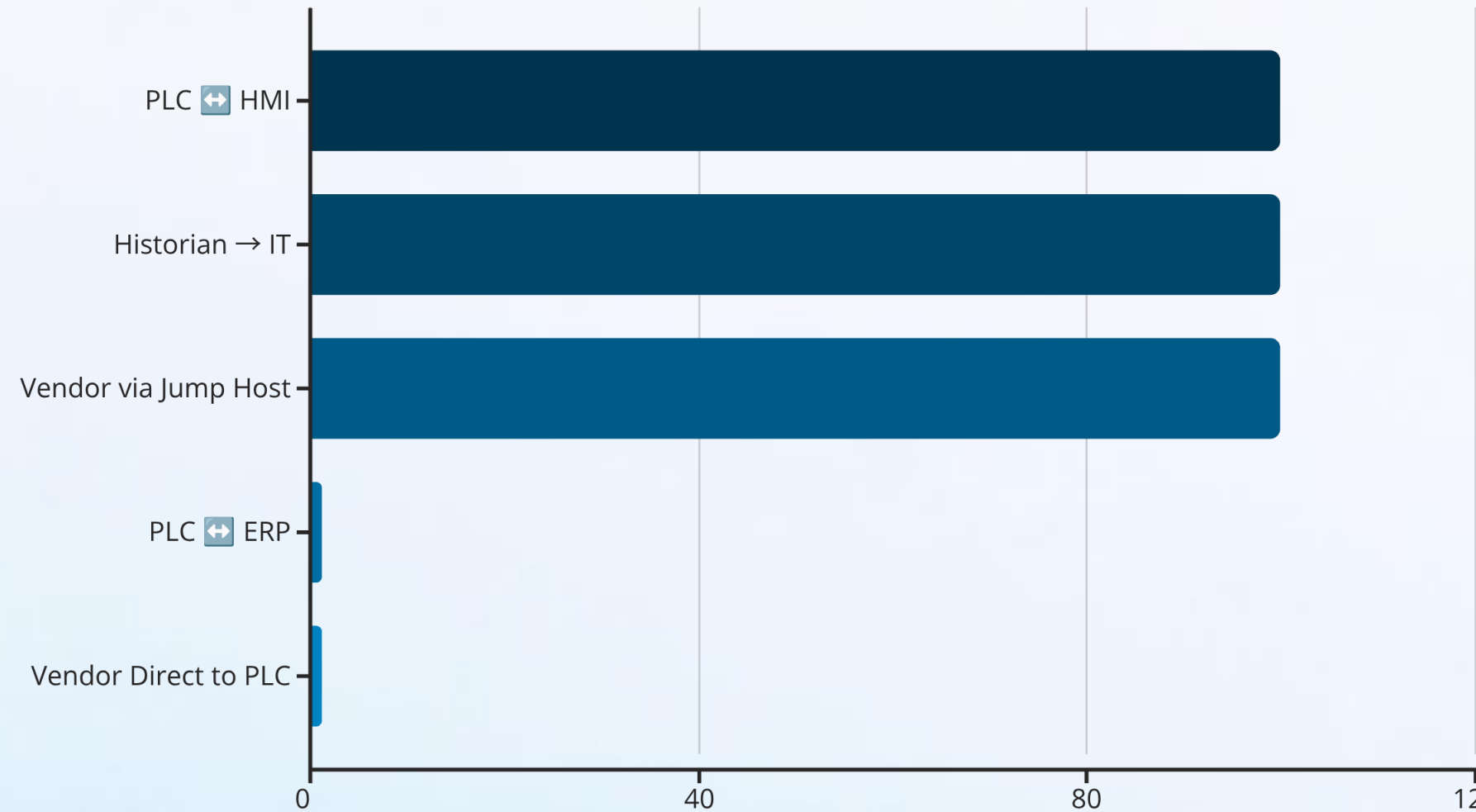
Document Every Allowed Path

Maintain formal documentation of why each conduit exists, what operational requirement it serves, and who approved its creation

Fundamental Rule: If communication is not explicitly required for safe and effective operations, it should not exist in the configuration—even if it seems harmless.

Examples of Allowed vs Blocked Paths

Translating segmentation principles into specific firewall rules requires understanding operational workflows and distinguishing necessary communication from convenient but risky shortcuts.



1 ✓ Allowed Paths

- **PLC ↔ HMI** — Required for operator control and process visualization
- **Historian → IT** — One-way data export for business analytics
- **Vendor laptop → PLC** — Only via authenticated jump host with session logging

2 ✗ Blocked Paths

- **PLC ↔ ERP** — No direct operational requirement, use historian as intermediary
- **Vendor direct to PLC** — Bypasses monitoring and creates unacceptable risk

Every design decision must be intentional, documented, and reviewed regularly. Ad-hoc "temporary" exceptions have a habit of becoming permanent vulnerabilities.

Designing Segmentation for a Cell

Effective segmentation starts small and scales up. Beginning with a single production cell or process unit allows teams to develop expertise before attempting site-wide deployments.

01	02	03
Identify Assets	Group into Zones	Define Required Communication
Catalog all devices—PLCs, HMIs, I/O modules, drives, sensors—and understand their communication requirements and dependencies	Create logical zones based on function and risk—field devices together, controllers in protected zone, operator interfaces separately	Map out which devices genuinely need to talk to each other for the cell to operate safely and effectively
04	05	
Assign Conduits	Validate Against Safety Needs	
Create specific conduits with protocol, direction, and timing restrictions for each necessary communication path	Review design with operations and safety teams to ensure segmentation doesn't interfere with emergency procedures or safety systems	

Cell-level design experience builds organizational knowledge and confidence, making site-wide security architecture more achievable and sustainable over time.

Segmentation Improves Resilience

While segmentation is often discussed as a security control, its benefits extend far beyond cybersecurity into operational resilience and business continuity.

- **Contain Faults**

Network storms, configuration errors, or device failures remain localized instead of cascading across the entire facility

- **Simplify Troubleshooting**

Clear boundaries make it easier to isolate problems, identify root causes, and implement fixes without affecting unrelated systems

- **Reduce Blast Radius**

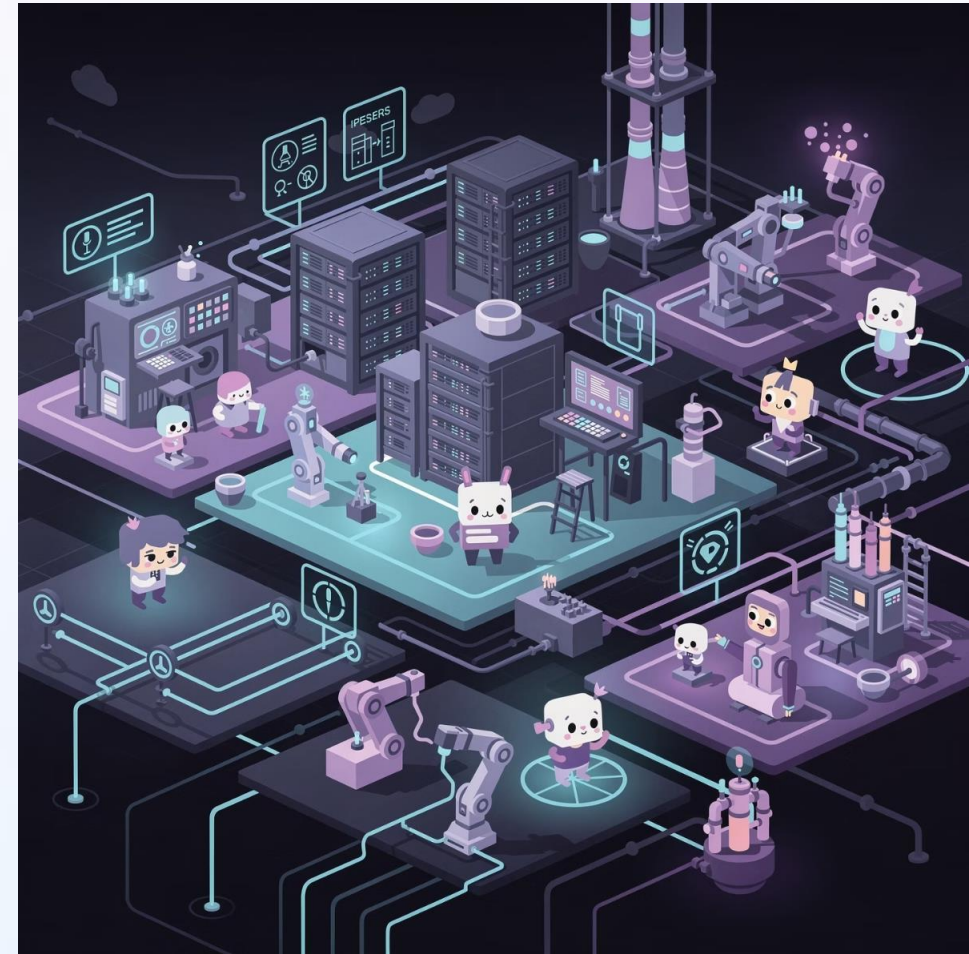
Whether dealing with cyber incidents or operational failures, segmentation limits the number of affected systems and production lines

- **Support Safer Maintenance**

Technicians can work on isolated zones with confidence that mistakes won't propagate to critical control systems

- **Enable Faster Recovery**

Segmented architectures allow for zone-by-zone restoration rather than requiring complete facility-wide recovery procedures



Key Insight: Resilience is a security outcome. Segmentation protects both against intentional attacks and unintentional operational disruptions.

Case Study: Pump Cell Segmentation

This practical example demonstrates how segmentation principles apply to a common OT scenario—a pump control cell in a water treatment or chemical processing facility.

	Field Zone Assets: Pressure sensors, flow meters, temperature probes, valve actuators Risk Profile: Direct physical interface, highest safety criticality, minimal intelligence
	Control Zone Assets: PLC running pump control logic, safety interlocks, sequencing programs Risk Profile: Real-time control execution, deterministic timing requirements, no external connectivity
	Supervisory Zone Assets: HMI for operator control, alarm management, trend visualization Risk Profile: Human interaction point, occasional configuration changes, higher connectivity needs

Allowed Communication

- **Sensor → PLC:** Process values every 100ms
- **PLC ↔ HMI:** Bidirectional control and visualization
- **HMI → Historian:** Trend data export (one-way)

Design Outcome

The PLC has no unnecessary exposure—it talks only to field devices it controls and the HMI that operators use. No direct enterprise connectivity, no vendor access, no external protocols.

Key Takeaways



Risk of Flat Networks

Flat networks dramatically increase OT risk by enabling rapid fault propagation and creating countless attack paths



Security Through Segmentation

Segmentation directly supports safety and availability by containing incidents and protecting critical systems



Purdue Model Framework

The Purdue Model helps place appropriate boundaries between levels with different risk profiles and operational requirements



Zones and Conduits

IEC 62443's zones and conduits provide a flexible, risk-based approach to structuring OT network communication



Jump Host Protection

Jump hosts enable necessary remote access while maintaining visibility, logging, and control over vendor activities



Least Privilege Principle

Apply least privilege to network communication itself—reduce accidental misuse and malicious exploitation through minimal necessary connectivity

Reflection & Class Discussion

Consider these key concepts from Module 07 as you prepare for discussion and complete your assignments.

Reflection & Class Discussion

- Why flat OT networks are risky for safety and availability
- How segmentation limits fault and incident spread
- Difference between zones and conduits
- Role of the Purdue Model in structuring OT networks
- Why vendor access must be controlled and monitored

Homework & Assignments

01

Explain why segmentation is critical in OT environments

02

Draw a simple Purdue Model and place OT assets correctly

03

Identify zones and conduits for a small pump control cell

04

List three least-privilege communication rules for OT systems

05

Describe the purpose of a jump host in vendor access management

What's Next

Authentication, Authorization & Key Management in OT

In the next module, you will learn how to control **who has access** to OT systems and what they're allowed to do once authenticated:

- Identity challenges unique to OT systems
- Authentication vs authorization—and why both matter
- Risks associated with shared credentials
- Role-based access control and service accounts
- Key and password management concepts for legacy systems
- Logging and audit trails for compliance
- Managing vendor and contractor access securely

From controlling network paths → to controlling who is allowed access.

Thank you. Let's continue with Module 08.